

Peer Response

Moses' post provides a well-structured overview of **OWASP A04: Cryptographic Failures** and clearly explains the importance of protecting sensitive data through strong encryption mechanisms. The discussion of UML sequence and component diagrams is a particular strength, as these models are well suited to analysing data flow and architectural separation of cryptographic responsibilities.

However, the real-world example of the **Equifax breach** would benefit from further clarification. While cryptographic protections are certainly relevant to the overall impact of the incident, multiple analyses identify the primary root cause of the 2017 Equifax breach as an **unpatched Apache Struts vulnerability**, rather than a failure of encryption design itself (Kabanov and Madnick, 2020). The initial compromise resulted from inadequate patch management and vulnerability remediation, which allowed remote code execution. Cryptographic controls became relevant only after the attacker had already gained access to internal systems. While some breached data was unprotected by encryption (EPIC, 2017), this was a consequence of the initial compromise via Apache Struts, not the root cause.

This distinction is important, as OWASP A04 focuses specifically on failures in how cryptography is applied to protect data, such as weak algorithms, poor key management, or missing encryption. In contrast, the Equifax incident aligns more directly with issues of **secure configuration, dependency management, and vulnerability handling**, which fall outside cryptography as a primary control category (OWASP, 2025). Clarifying this separation would strengthen the analytical precision of the example.

One way to improve alignment might be to either explicitly frame Equifax as a **compound failure**, where cryptographic protections failed to limit impact after initial compromise, or to select a case study where cryptographic weakness itself was the initiating factor. A useful reflection could be whether the presented flowchart models exploitation *before* or *after* system compromise, and how this affects the categorisation of the vulnerability.

References

EPIC (2017) Equifax Data Breach. Available at:
<https://archive.epic.org/privacy/data-breach/equifax/>

Kabanov, I. and Madnick, S. (2020) *A systematic study of the control failures in the Equifax cybersecurity incident*. MIT Sloan Research Paper No. 2020–19.

OWASP (2025) *A04: Cryptographic Failures*. Open Web Application Security Project.